

CISM Domain 3A — InfoSec Program Development: Exam Essentials

Domain 3 (Information Security Program) = 33% of the exam ≈ 50 of 150 questions — the BIGGEST domain. Part A covers program resources (3A1), asset identification & classification (3A2), standards & frameworks (3A3), policies/procedures/guidelines (3A4), and metrics (3A5).

What Is the IS Program? (3A1)

- The program is the **execution of the strategy** — people + processes + technology protecting information assets. Analogy: governance = rules of the road, strategy = the route, **program = the car making the trip**.
- **Six outcomes** (same as governance — know them!): strategic alignment, risk management, value delivery, resource management, performance measurement, assurance process integration.
- Basic functions: protect assets, ensure compliance, enable incident response, reduce liability.
- **Charter** = formal document granting authority; describes the program's **mission, vision, roles & responsibilities, and processes** (exam answer). Senior leadership sponsors it and stays ultimately accountable.
- **Lack of executive support = FATAL** hurdle. Others: inadequate resources, cultural resistance, business misalignment, complexity, poor metrics, scope creep.

Roadmap Development (know the sequence)

1. Align with business strategy & frameworks (COBIT, ISO 27001/27002, NIST CSF)
2. Assess CURRENT security state
3. Define TARGET security state
4. Analyze the GAPS
5. Create action plan (prioritized initiatives, timelines, resources)
6. Implement & monitor using metrics

SDLC (ISACA's 5 phases) — build security in from the START

1. **Initiation** — define/align security requirements with business objectives
2. **Development/Acquisition** — incorporate controls into design and code
3. **Implementation** — test and validate controls before go-live
4. **Operations & Maintenance** — monitor and update controls
5. **Disposal** — securely archive/destroy data, decommission systems

Integrating security at each stage avoids expensive, disruptive fixes later — never bolt security on afterward.

Asset Identification & Classification (3A2)

- **Asset valuation = Criticality × Sensitivity**. Sensitivity = CIA damage if leaked/altered/unavailable (about the DATA). Criticality = how essential to business operations (about the BUSINESS).
- Don't underestimate **intangible value** (reputation, customer trust) — ignoring it produces flawed risk assessments.
- The **data owner (a business manager, not IT)** makes classification decisions; IT implements the required controls as custodian.

- **Classification levels:** government: Top Secret / Secret / Confidential / Unclassified; private sector: Confidential-Proprietary / Private / Sensitive / Public. Keep the number of levels PRACTICAL — clarity and usability over precision.
- Classification must **drive handling requirements:** storage (encryption at rest), transport (TLS), access (need-to-know). Review classifications periodically — MANDATORY.
- **BIA** provides the evidence for criticality and justifies control levels; identifies dependencies and quantifies impact over time.
- **Top-down** approach: business functions → assets (business process owners drive). **Bottom-up:** aggregate asset vulnerabilities upward (security leaders drive).

Information Lifecycle (protect cradle to grave)

1. **Create** (by users or systems)
2. **Classify** — as soon as possible after creation; data can only be fully secured when its sensitivity is known
3. **Store** — encrypt at rest (symmetric, e.g., AES)
4. **Use** — access controls + DLP in use; TLS in transit
5. **Archive** — retain securely for legal/regulatory compliance
6. **Destroy** — unreadable AND unrecoverable; data kept longer than necessary = more risk

Data Protection Technologies

- **DRM** — content owners enforce usage restrictions (music, e-books; occasionally enterprise docs).
- **DLP** — identifies, monitors, and protects sensitive data; alerts on oversharing/policy violations; spans detective, preventive, corrective; applied to email, SharePoint, cloud storage, removable media, databases. Protection travels WITH the document.
- **CASB** — security policy enforcement for cloud services; visibility into **shadow IT**.
- **Privacy principles:** purpose limitation (use data only for the disclosed purpose) and data minimization (collect only what's necessary — age category, not birth date).

Technique	What it does
Data masking	Only partial data shown (**** * 1234); usually at the database tier
Anonymization	Removes all identifying data — IRREVERSIBLE; only works if you don't need identity
Tokenization	Random token replaces data; original held in a vault — stateless, stronger than encryption (no local keys)
Pseudonymization	PII fields replaced with pseudonyms — REVERSIBLE with access to a separate data source

Standards & Frameworks (3A3)

Framework type	Focus	Examples
Control frameworks	WHAT controls to implement	CIS CSC, ISO 27002, NIST SP 800-53, PCI DSS

Risk mgmt frameworks	HOW to identify/assess/treat/monitor risk	ISO 27005, ISO 31000, NIST CSF, NIST SP 800-37
Program mgmt frameworks	HOW to run/govern/improve the whole program (ISMS)	ISO 27001, NIST CSF, COBIT

- Want to build an **ISMS** → **ISO/IEC 27001** (management system requirements; ISO 27002 supplies the control guidance) — classic exam question.
- **NIST CSF** six functions: Govern, Identify, Protect, Detect, Respond, Recover — voluntary, risk-based, widely adopted.
- **NIST RMF** (SP 800-37): Prepare, Categorize, Select, Implement, Assess, Authorize, Monitor — mandatory for US federal agencies.
- **EISA** = the security blueprint within enterprise architecture — security by design, not bolted on. Approaches: SABSA (business-driven, layered), TOGAF (broader EA). Know WHY you use one, not the internals.
- Program components to cover: **technical** (firewalls, SIEM), **operational** (patching, access reviews, IR), **management** (risk processes, metrics, policy approval), **administrative** (policies, roles), **educational** (awareness).

Policies, Standards, Procedures, Guidelines (3A4) ⚠️ guaranteed questions

Document	Question	Mandatory?	Description / Example
Policy	WHY	Mandatory	High-level management statement of direction — “We protect the CIA of our information assets”
Standard	WHAT	Mandatory	Specific technical requirements — “Card data must be encrypted at rest/in transit with a compliant algorithm”
Procedure	HOW	Mandatory	Step-by-step instructions — “1. Isolate system, 2. Notify security team, 3. Document incident”
Guideline	COULD	Optional	Recommendations/best practices — “Employees are encouraged to attend awareness training”

House analogy: policy = blueprint, standard = building codes, procedure = construction instructions, guideline = optional design tips.

Program Metrics (3A5)

- **SMART**: Specific, Measurable, Achievable, Relevant, Time-bound. Plus: **actionable** (must drive a decision), audience-specific, outcome-focused, trend-spotting, reliable, ideally predictive.
- **Three levels**: strategic (exec: ROI, risk posture), management (program: policy compliance rates, audit finding closure), operational (technical: patch timeliness, scan results, response times).
- Metric frameworks: NIST SP 800-55, ISO/IEC 27004, COBIT, Balanced Scorecard — toolkits, not rigid rules.

- Metrics alone can't answer "how secure are we?" — that needs risk assessments and security audits for context.

Metric	Time focus
KGI	PAST — reports results after the fact (goal achieved?)
KPI	PRESENT — current performance; some trend forecasting
KRI	FUTURE — predicts potential roadblocks/rising risk (leading indicator)
CSF	Underpins all — the essential factors that must go right

Leading indicator example: % increase in patch compliance — it predicts reduced probability of future incidents (exam answer). Blocked attacks and time-to-mitigate are lagging.

Quick Self-Check (from the handout)

1. Document describing program mission, vision, roles, processes? → **Charter**
2. Document with required methods to protect data at rest/in transit/in use? → **Data classification policy**
3. Standard for developing an ISMS? → **ISO/IEC 27001**
4. Detailed doc for complying with a policy? → **Procedure**
5. Best leading indicator? → **% increase in patch compliance on critical servers**

Last-Minute Memory Hooks

- Program = the car; strategy = the route; governance = rules of the road
- Policy WHY → Standard WHAT → Procedure HOW → Guideline COULD (only guidelines are optional)
- Data owner (business) classifies; IT (custodian) implements
- Valuation = criticality (business ops) × sensitivity (CIA damage)
- Classify data ASAP after creation; destroy when no longer needed
- ISO 27001 = ISMS management system; ISO 27002 = the controls
- KGI past, KPI present, KRI future
- No executive support = program death